

T1.3.D — endpoint /internal/stripe-event con HMAC

Implementación · Rama `pr/t1.3.d-internal-stripe-event` · Commit `4f5c9ef` · 2026-05-02

Status: Branch pusheado a GitHub. Tests verdes (26 nuevos · 554 totales). **NO mergeado a main.** Owner aprueba via PR en GitHub UI.

Antes de mergear: generar valor de `INTERNAL_BRIDGE_SECRET` y configurar la **misma** variable en Vercel (landing) y Render (backend). Sin esto, el deploy a producción aborta por fail-fast al import de `agent.main`.

1. Archivos cambiados

Archivo	Δ líneas	Tipo	Rol
agent/main.py	+131 / -0	M	fail-fast + helper + endpoint
.env.example	+21 / -0	M	doc INTERNAL_BRIDGE_SECRET
tests/test_main_internal_stripe.py	+558 / -0	A	26 tests
TOTAL T1.3.D	+710 / -0	3 archivos	

2. Resumen del diff

agent/main.py — 3 bloques nuevos

(a) Imports añadidos:

```
import json
import hashlib
```

(b) Fail-fast al import (línea ~38):

```
def _check_internal_bridge_secret() -> None:
    env = os.getenv("ENVIRONMENT", "development").lower()
    if env == "production" and not os.getenv(
        "INTERNAL_BRIDGE_SECRET", "").strip():
        raise RuntimeError(...)

_check_internal_bridge_secret() # se ejecuta al import
```

(c) Helper HMAC (compare_digest):

```
def _verificar_firma_interna(body: bytes, sig_header: str) -> bool:
    secret = os.getenv("INTERNAL_BRIDGE_SECRET", "").strip()
    if not secret or not sig_header:
        return False
    esperado = hmac.new(
        secret.encode("utf-8"), body, hashlib.sha256
    ).hexdigest()
    return hmac.compare_digest(esperado, sig_header.strip())
```

(d) Endpoint POST /internal/stripe-event:

```

@app.post("/internal/stripe-event")
async def internal_stripe_event(request: Request):
    body = await request.body()
    sig = request.headers.get("X-Internal-Signature", "")
    if not _verificar_firma_interna(body, sig):
        raise HTTPException(401, "signature_invalid")
    try:
        evento = json.loads(body.decode("utf-8"))
    except (UnicodeDecodeError, json.JSONDecodeError):
        raise HTTPException(400, "json_invalid")
    if not isinstance(evento, dict):
        raise HTTPException(400, "json_not_object")
    try:
        resultado = await procesar_evento_suscripcion(evento)
    except Exception:
        raise HTTPException(500, "processing_error")
    # Solo race invoice→checkout amerita 500 retryable.
    if not resultado.get("handled"):
        if (evento_tipo == "invoice.payment_succeeded" and
            razon == "subscription_no_persistida"):
            raise HTTPException(500, "...retry")
    return {"status": "ok", **resultado}

```

NO modificado: /webhook/stripe legacy queda intacto.

3. Clasificación de respuestas HTTP

Decisión de diseño: **la mayoría de los handled=False son 200, no 500**. Solo casos genuinamente retryable devuelven 500 — evita que Stripe (vía bridge) reentregue eventos rotos eternamente.

Status	Cuándo	Razón
200	handled=True	Procesado OK
200	duplicate_event	Ya procesado (idempotencia general)
200	invoice_ya_acreditado	Ya acreditado (idempotencia invoice)
200	missing_telefono	Evento incompleto, retry no ayuda
200	missing_event_id	Evento incompleto, retry no ayuda
200	missing_subscription_id (checkout)	Evento incompleto
200	missing_invoice_id	Evento incompleto
200	plan_invalido	Config faltante; retry tras arreglar
200	tipo no soportado	Fuera de scope
200	checkout mode=payment	Lo maneja /webhook/stripe legacy
200	subscription_no_persistida (updated/deleted)	No es race; sub realmente no existe
500	subscription_no_persistida (invoice)	Race con checkout; pedir retry
500	Excepción inesperada	Bug; retry da una segunda chance
400	JSON inválido (tras HMAC válido)	Bug en bridge; alertar
400	JSON no objeto	Bug en bridge; alertar
401	Sin firma o firma inválida	Atacante o secret desincronizado

4. Tests ejecutados

Archivo nuevo: **tests/test_main_internal_stripe.py** (558 líneas, 26 tests). Patrón: TestClient de FastAPI con monkeypatch.setenv para inyectar INTERNAL_BRIDGE_SECRET="test-secret-not-real" y un DB SQLite en tmp_path.

Clase de tests	N°	Cubre
TestFirmaInvalida	5	Sin header, header vacío, firma inválida, firma de otro secret, body modificado tras firmar
TestFirmaValidaProcesa	2	Checkout válido crea suscripción; invoice acredita via endpoint
TestJsonInvalido	3	Body no JSON, body es array no objeto, body vacío
TestDuplicateEvent	1	Mismo event.id reentregado → 200 no 500
TestInvoiceYaAcreditado	1	Mismo invoice_id distinto event_id → 200 no 500
TestRaceInvoiceCheckout	3	Invoice sin sub → 500; updated/deleted sin sub → 200 (no race)
TestNoRetryable	5	missing_telefono, plan_invalido, missing_event_id, tipo no soportado, mode=payment
TestFailFastProduccion	4	Production sin secret → RuntimeError; whitespace → falla; con secret no falla; dev sin secret no falla
TestLegacyWebhookIntacto	2	/webhook/stripe sigue registrado y la función no cambió

Resultado

```
$ pytest tests/test_main_internal_stripe.py -x --tb=short
===== 26 passed in 27.42s =====

$ pytest --tb=short -q
554 passed in 171.09s (0:02:51)

Baseline pre-T1.3.D: 528 tests
Δ = +26 tests T1.3.D
```

5. Blockers

Ninguno. Tests verdes, branch pusheado a remote. Listo para PR review en GitHub.

6. Próximos pasos para el owner

a) Generar INTERNAL_BRIDGE_SECRET

```
python -c "import secrets; print(secrets.token_urlsafe(32))"
```

b) Configurar el MISMO valor en dos lugares

- **Render** (backend): variable de entorno *INTERNAL_BRIDGE_SECRET*.
- **Vercel** (landing): variable de entorno *INTERNAL_BRIDGE_SECRET*.
- Ambos deben ser idénticos byte a byte (sin espacios, sin saltos).
- Si los valores difieren, el endpoint rechaza con 401 todos los eventos.

c) Mergear T1.3.D

- PR T1.3.D: <https://github.com/celestinojbm/Dona-agent/compare/main...pr/t1.3.d-internal-stripe-event>

- El endpoint queda **desplegado pero sin tráfico** hasta T1.3.E.
- Stripe Dashboard sigue apuntando a la landing.

d) Continuar con T1.3.E

T1.3.E = bridge en **landing/app/api/webhook/route.ts**: tras verificar la firma de Stripe, computa HMAC-SHA256 sobre el body crudo con INTERNAL_BRIDGE_SECRET y POSTea a *{BACKEND_URL}/internal/stripe-event*. Si el backend devuelve 500, devuelve 500 a Stripe para que reintente. Si devuelve 200, responde 200 a Stripe.

Generado por Claude Code · Modelo Opus 4.7 · Sesión 2026-05-02 · Repo: Dona-agent · Branch: pr/t1.3.d-internal-stripe-event · HEAD: 4f5c9ef